BEZPIECZNE TRANSAKCJE ELEKTRONICZNE · KAMIEŃ MILOWY KM1

Analiza porównawcza mechanizmów uwierzytelniania
Baza źródłowa, założenia i kryteria oceny

Zespół: Kamil Szkarłat (koordynator), Jakub Szkaradek, Bartłomiej Ząbek, Radosław Chruściński, Wojciech Śliwa, Mikołaj Mierzwa · 08.11.2026

1. Jak czytać tę bazę

Źródła pogrupowano w 6 kategorii:

1. **Normy, standardy i regulacje** — fundament wymagań (co *musi* spełniać silne uwierzytelnianie).
2. **Specyfikacje techniczne i RFC** — jak protokoły działają „pod maską".
3. **Publikacje naukowe** — recenzowane badania bezpieczeństwa i UX (rdzeń analizy porównawczej).
4. **Ataki i studia przypadków** — udokumentowane incydenty i wektory (phishing, MitM/AitM, SIM-swap, relay).
5. **Raporty branżowe** — dane wdrożeniowe i trendy (B2B/B2C/C2C).
6. **Projekty, repozytoria i wizualizacje** — inspiracje techniczne pod moduł demo (zadanie E).

Każde źródło opisano: **[typ] • rok • relevancja** oraz przypisano do zadania z wykresu PERT (B1 = OTP/MFA, B2 = FIDO2/biometria, B3 = B2B/B2C/C2C/UX, C = ataki/matryca, D = metodyka ochrony, E = wizualizacja).

> **Legenda typów:** `norma` = standard/regulacja, `spec` = specyfikacja techniczna, `recenz.` = publikacja recenzowana (konferencja/czasopismo), `preprint` = arXiv/ResearchGate (do weryfikacji statusu), `raport` = raport branżowy, `repo` = kod/wizualizacja.

2. Normy, standardy i regulacje `[→ cały projekt, B1, B2, C, D]`

#	Źródło	Typ	Dlaczego istotne
N1	**NIST SP 800-63B-4 — Digital Identity Guidelines: Authentication & Authenticator Management** (wersja finalna, lipiec 2025) — PDF · HTML · strona NIST	norma	Definiuje **poziomy pewności uwierzytelnienia AAL1–AAL3** i kryterium „phishing-resistant". Rdzeń naszej osi „zgodność/bezpieczeństwo". SMS klasyfikowany jako *restricted*.
N2	**NIST SP 800-63-4 (pakiet: -63, -63A, -63B, -63C)** — strona NIST	norma	Kontekst całej rodziny: identity proofing, federacja, zarządzanie cyklem życia.

#	Źródło	Typ	Dlaczego istotne
N3	**PSD2 — Dyrektywa (UE) 2015/2366** + **Rozporządzenie delegowane (UE) 2018/389 (RTS SCA)** — EUR-Lex 2018/389 · Opinia EBA nt. elementów SCA, 06.2019 (omówienie)	norma	**Silne Uwierzytelnianie Klienta (SCA)** = ≥2 niezależne elementy z 3 kategorii (wiedza / posiadanie / cecha). Kluczowe dla kontekstu transakcji elektronicznych i relacji B2C/B2B. Obowiązuje od 14.09.2019. EMV 3-D Secure nie liczy się jako „inherence". PSD2 jest zastępowane pakietem **PSD3 + PSR**, w którym SCA zostaje utrzymane i wzmocnione (adaptacyjne, risk-based).
N4	**OWASP Multifactor Authentication Cheat Sheet** — link oraz **Authentication Cheat Sheet** — link	norma	Praktyczne wytyczne: dwa składniki tego samego typu ≠ MFA; passkeys łączą posiadanie + wiedza/cecha; risk-based MFA. Baza do zadania D (rekomendacje).
N5	**OWASP Top 10 (2021) — A07: Identification and Authentication Failures** — link	norma	Mapuje typowe błędy uwierzytelniania na ryzyka aplikacyjne.
N6	**ISO/IEC 27001 / 27002** (zarządzanie bezpieczeństwem informacji), **ISO/IEC 29115** (entity authentication assurance), **ISO/IEC 30107-1/-3** (Presentation Attack Detection) — iso.org	norma	30107 definiuje PAD — niezbędne przy ocenie biometrii (B2). 29115 = ramy poziomów pewności.
N7	**ENISA — „On the security and privacy of eID & authentication in e-finance/e-payments" (2013)** + pakiet eIDAS (2021) — ENISA eIDAS4eFinance (PDF)	raport/norma	Europejski kontekst regulacyjny; dopasowanie siły metody do ryzyka transakcji.

3. Specyfikacje techniczne i RFC `[→ B1, B2, E]`

#	Źródło	Typ	Dlaczego istotne
S1	**W3C Web Authentication (WebAuthn) Level 3** — Rekomendacja W3C (25.08.2026) — TR	spec	Oficjalne API przeglądarkowe dla kluczy FIDO2/passkeys. Fundament B2 i demo E.
S2	**FIDO Alliance — specyfikacje FIDO2: CTAP2 (Client to Authenticator Protocol) + WebAuthn** — fidoalliance.org/specifications	spec	Jak klucz sprzętowy rozmawia z klientem; kryptografia klucza publicznego, odporność na phishing.
S3	**RFC 6238 — TOTP: Time-Based One-Time Password Algorithm** (M'Raihi i in., 2011) — IETF	spec	Działanie aplikacji typu Google/Microsoft Authenticator (B1). Rozszerza HOTP o czynnik czasu; HMAC-SHA-1/256/512.
S4	**RFC 4226 — HOTP: HMAC-Based One-Time Password Algorithm** (M'Raihi i in., 2005) — IETF	spec	Baza matematyczna OTP (licznikowy).
S5	**EMVCo — Contactless Specifications / EMV 3-D Secure** — emvco.com	spec	Standard kart zbliżeniowych i uwierzytelniania płatności (karty zbliżeniowe/magnetyczne — zakres projektu).

4. Publikacje naukowe (rdzeń analizy)

4a. FIDO2 / WebAuthn / passkeys — bezpieczeństwo i UX `[→ B2, B3]`

#	Źródło	Typ	Dlaczego istotne
P1	**Lyastani i in. — „Is FIDO2 the Kingslayer of User Authentication? A Comparative Usability Study of FIDO2 Passwordless Authentication"**, IEEE S&P 2020 — PDF	recenz.	**Najczęściej cytowane** porównawcze badanie użyteczności FIDO2. Punkt odniesienia dla osi UX.
P2	**„FIDO2 the Rescue? Platform vs. Roaming Authentication on Smartphones"**, **ACM CHI 2023** (DOI 10.1145/3544548.3580993) — arXiv PDF	recenz.	Porównanie uwierzytelniania platformowego (biometria w telefonie) vs. klucz roaming.
P3	**„Challenges with Passwordless FIDO2 in an Enterprise Setting: A Usability Study"**, **IEEE SecDev 2023** — arXiv HTML	recenz.	Badanie 118 profesjonalistów — bariery wdrożeniowe w B2B. Użytkownicy nie rozumieją przewagi „phishing-resistant" nad push.
P4	**Lassak i in. — „Why Aren't We Using Passkeys? Obstacles Companies Face..."**, USENIX Security 2024; oraz badanie SOUPS 2025 — PDF SOUPS 2025	recenz.	Przeszkody adopcji passkeys; porównanie kluczy (PIN/biometria) vs. hasło+TOTP.
P5	**„Device-Bound vs. Synced Credentials: A Comparative Evaluation of Passkey Authentication"**, **ICISSP 2025** — arXiv PDF	recenz.	Kluczowe rozróżnienie: passkey związany z urządzeniem vs. synchronizowany (B2C vs. B2B).
P6	**NCSC (UK) — „Comparing the security properties of traditional user credentials and FIDO2 credentials for personal use"** — link	raport/recenz.	Gotowa tabela odporności (AitM phishing: „never vulnerable" dla FIDO2 vs. „always" dla hasła). Wzór pod naszą matrycę (C).

4b. MFA / 2FA — kompromis bezpieczeństwo ↔ wygoda `[→ B1, B3, C]`

#	Źródło	Typ	Dlaczego istotne
P7	**Karim i in. — przegląd porównawczy metod MFA** (SMS, voice, FIDO2, biometria wg bezpieczeństwa/UX/kosztu/kompatybilności), *Int. J. of Data and Network Science*, 2023 — PDF	recenz.	**Najbliższe naszemu tematowi** istniejące porównanie wielokryterialne. Wzorzec metodyczny matrycy.
P8	**„A Comparative Usability Study of Two-Factor Authentication"**, **USEC 2014** (wersja wstępna) — arXiv PDF	recenz.	Klasyczne źródło: użytkownicy przedkładają wygodę nad bezpieczeństwo; znajomość metody > postrzegana użyteczność.
P9	**„Evaluating User Perception of Multi-Factor Authentication: A Systematic Review"** — ResearchGate	preprint	Przegląd systematyczny percepcji MFA; obowiązkowe MFA bez edukacji bywa nieskuteczne.
P10	**AuthGuide — „Analyzing Security, Privacy and Usability Trade-offs in MFA"**, KU Leuven — PDF	recenz.	Trójosiowy kompromis bezpieczeństwo/prywatność/UX — bezpośrednio wspiera naszą oś oceny.
P11	**Amft i in. — „We've Disabled MFA for You: An Evaluation of the Security and Usability of MFA Recovery Deployments"**, arXiv 2306.09708 — PDF	preprint	Odzyskiwanie konta (security questions, kody zapasowe) osłabia nawet passwordless — ważne dla D.

#	Źródło	Typ	Dlaczego istotne
P12	**Lyastani i in. — „A Systematic Study of the Consistency of 2FA User Journeys on Top-Ranked Websites" (Extended Version)**, arXiv 2210.09373 — PDF	preprint	Jak realne serwisy wdrażają 2FA — materiał do B3 (praktyka B2C).

4c. Biometria i Presentation Attack Detection `[→ B2, C]`

#	Źródło	Typ	Dlaczego istotne
P13	**„Audio-Visual Biometric Recognition and Presentation Attack Detection: A Comprehensive Survey", IEEE Access, vol. 9, s. 37431–37455, 2021** — arXiv PDF	recenz.	Szeroki przegląd modalności biometrycznych + ataki prezentacji (replay/spoofing).
P14	**„A comprehensive survey of fingerprint presentation attack detection"**, *J. Surveill. Secur. Saf.* — link	recenz.	Metody hardware/software wykrywania spoofingu odcisku palca.
P15	**Marasco i in. — „Biometric multi-factor authentication: on the usability of the FingerPIN scheme"**, *Security and Privacy* (Wiley), 2023 — link	recenz.	Badanie UX hybrydy biometria+PIN (100 uczestników) — balans bezpieczeństwo/UX.
P16	**„Presentation attack detection and biometric recognition in a challenge-response formalism"**, *EURASIP J. Information Security*, 2022 — link	recenz.	Challenge-response jako obrona przed atakami prezentacji (freshness).

5. Ataki i studia przypadków `[→ C, D]`

#	Źródło	Typ	Dlaczego istotne
A1	**Kikuchi — „Impact Assessment of Adversary-in-the-Middle Attack: Evilginx Bypassing 2FA"**, Springer 2025 — rozdział	recenz.	**Recenzowane** potwierdzenie: ok. 80% badanych serwisów podatnych na AitM; tylko FIDO2/WebAuthn odporne. Kluczowe dla matrycy C (phishing/MitM).
A2	**MFA Fatigue / Push Bombing — włamanie do Uber (wrzesień 2022, Lapsus$)** — BleepingComputer	raport	Sztandarowe studium przypadku ataku zmęczeniowego na push. Obrona: **number matching**. Idealne do prezentacji dla licealistów.
A3	**DEKRA — „From SMS to SIM: Security Analysis of Phone Number Verification"** — link	raport	Analiza słabości SMS-OTP: phishing, **SIM-swap**, SS7, złośliwe aplikacje. Argument „dlaczego SMS = restricted".
A4	**Basin i in. — „The EMV Standard: Break, Fix, Verify" / PIN bypass kart zbliżeniowych** — omówienie	recenz.	Formalna analiza EMV; atak obejścia PIN (Visa). Dla zakresu „karty zbliżeniowe".
A5	**„Practical EMV Relay Protection"**, IEEE S&P 2022 — IEEE · **„Security Analysis and Implementation of Relay-Resistant Contactless Payments"**, ACM CCS 2020 — ACM	recenz.	Ataki **relay** na płatności zbliżeniowe (m.in. obejście blokady Apple Pay); protokoły distance-bounding jako obrona.
A6	**Hofmeier, Basin i in. — „SoK: Attacks on Modern Card Payments"**, arXiv 2504.03363 (04.2025) — PDF	preprint	**Najświeższa** systematyzacja ataków na karty płatnicze; większość kart EMV wciąż ma podatny na klonowanie pasek magnetyczny. Rdzeń dla mechanizmu „karty zbliżeniowe/magnetyczne".

#	Źródło	Typ	Dlaczego istotne
A7	**Scaife i in. — „Fear the Reaper: Characterization and Fast Detection of Card Skimmers"**, USENIX Security 2018 — PDF	recenz.	**Skimming** paska magnetycznego; detektor Skim Reaper. EMV ma pasek jako backup — nadal klonowalny.
A8	**Roland, Langer — „Cloning Credit Cards: A Combined Pre-play and Downgrade Attack on EMV Contactless"**, USENIX WOOT 2013 — PDF	recenz.	Klonowanie przez skimming zbliżeniowy + wymuszenie trybu magstripe.
A9	**„Security Analysis of Near-Field Communication (NFC) Payments"**, arXiv 1904.10623 — PDF	preprint	Pasek magnetyczny daje minimalne bezpieczeństwo (oparte na fizycznym posiadaniu); PoC przepisania danych track.

6. Raporty branżowe i dane wdrożeniowe `[→ B3, D]`

#	Źródło	Typ	Dlaczego istotne
R1	**FIDO Alliance — Online Authentication Barometer 2024** — PDF	raport	Znajomość passkeys 57% (2024, wzrost z 39% w 2022). Dane konsumenckie B2C.
R2	**FIDO Alliance — The State of Passkeys 2026 (Consumer & Workforce)** — link	raport	Podział B2C (synced) vs. workforce/B2B (device-bound). Trendy adopcji.
R3	**ENISA — bieżące raporty o uwierzytelnianiu i eIDAS** — enisa.europa.eu	raport	Źródło europejskie uzupełniające NIST (US).

7. Projekty, repozytoria i wizualizacje (pod zadanie E) `[→ E]`

> Zbierane wstępnie — szczegółowy wybór techniczny nastąpi w etapie E (prototyp do 15.01).

#	Źródło	Typ	Dlaczego istotne
W1	**Wzorzec wizualny — „Protocol Explorer" (`protocol-explorer-alpha.vercel.app`)**	repo	Referencja stylu UI, którą wskazał zespół (edukacyjny explorer „jak działa internet", prawdopodobnie Next.js/React). **Uwaga:** publiczne repo źródłowe nie zostało jednoznacznie zlokalizowane — do ustalenia (kontakt z autorem / inspekcja nagłówków) lub odtworzenie stylu 1:1 od zera.
W2	**systemslibrarian/crypto-lab-webauthn** — ecosyste.ms	repo	Interaktywne demo WebAuthn z **prawdziwymi kluczami ECDSA P-256** i symulacją ataków (phishing/replay/clone) + przycisk reset. Świetne na dzień otwarty.
W3	**Zack Proser — „What happens when you sign in with a passkey?"** (interaktywny explainer warstwowy) — link	repo	Wzorzec „rozstrzelonej" animacji przepływu uwierzytelnienia — dokładnie estetyka, o którą nam chodzi.
W4	**yackermann/awesome-webauthn** (kuratorowana lista dem i narzędzi) — link · **passkeys.dev/demos** — link	repo	Katalogi gotowych dem i testerów WebAuthn do zapożyczenia.

#	Źródło	Typ	Dlaczego istotne
W5	**Authgear Passkey Demo / WebAuthn Tester** (źródło: `oursky/authgear-web`) — narzędzie	repo	Pokazuje krok po kroku weryfikację po stronie serwera — dobry model „pod maską".

8. Szczegółowe założenia analizy

8.1. Badane mechanizmy (jednostki porównania)

1. **Hasło** (punkt odniesienia / baseline)
2. **SMS OTP** (kod jednorazowy przez SMS)
3. **TOTP / aplikacja uwierzytelniająca** (RFC 6238)
4. **Powiadomienie Push** (w tym wariant z *number matching*)
5. **Klucz sprzętowy FIDO2 / WebAuthn** (roaming authenticator)
6. **Passkey** (device-bound oraz synced)
7. **Biometria** (odcisk palca / twarz; jako czynnik „cecha")
8. **Karty zbliżeniowe / magnetyczne** (posiadanie; kontekst płatności)
9. **MFA** (kombinacja ≥2 powyższych)

8.2. Kryteria oceny (osie matrycy porównawczej)

Każdy mechanizm oceniany w skali **1–5** (1 = najsłabszy, 5 = najlepszy) w wymiarach:

A. Bezpieczeństwo (odporność na wektory ataków): - A1 — Phishing / AitM (adversary-in-the-middle) - A2 — MitM / przechwycenie kanału - A3 — Replay / powtórzenie - A4 — SIM-swap / przejęcie kanału telekomunikacyjnego - A5 — Socjotechnika (w tym MFA fatigue) - A6 — Wyciek z serwera / baza poświadczeń - A7 — Przejęcie/utrata urządzenia

B. Uniwersalność i wdrażalność: - B1 — Koszt wdrożenia (infrastruktura, sprzęt) - B2 — Interoperacyjność / wsparcie platform i przeglądarek - B3 — Skalowalność

C. Funkcjonalność dla użytkownika (UX): - C1 — Tarcie / liczba kroków - C2 — Czas uwierzytelnienia - C3 — Dostępność (accessibility) i odzyskiwanie konta (recovery) - C4 — Krzywa uczenia / znajomość metody

D. Zgodność i dopasowanie: - D1 — Poziom NIST AAL (1–3) - D2 — Spełnienie PSD2 SCA (tak/częściowo/nie) - D3 — Status „phishing-resistant" (tak/nie) - D4 — Dopasowanie do relacji **B2B / B2C / C2C**

8.3. Metodyka oceny

- Dla każdej pary (mechanizm × kryterium) — ocena 1–5 z **uzasadnieniem opartym na źródle** z tej bazy (nr źródła w przypisie).
- Wektory ataków (sekcja A) oceniane głównie wg źródeł recenzowanych (P1, P6, A1–A5) oraz norm (N1, N4).
- Wynik zbiorczy = matryca + waga kryteriów dobrana osobno dla B2B, B2C, C2C (inne priorytety: B2B ceni bezpieczeństwo/zgodność, C2C ceni UX/koszt).
- Rekomendacje (zadanie D) = „najefektywniejsze zastosowanie" każdej metody (gdzie, po co, dlaczego) wyprowadzone z matrycy.

8.4. Produkty końcowe (zgodnie z planem)

- **Matryca porównawcza** (arkusz + tabela w raporcie) — KM2 (13.12).
- **Metodyka przeciwdziałania** (rekomendacje ochronne) — do 03.01.
- **Wizualizacja webowa** (demo, styl „Protocol Explorer") — KM3 (15.01).
- **Raport naukowy (LaTeX/Overleaf) + prezentacja** — KM4 (23.01).

Przy cytowaniu w raporcie końcowym stosować pełny opis bibliograficzny: autor, tytuł, wydawca/konferencja, rok, DOI/URL.